

SECURITY AUDIT REPORT

CentOS Infrastructure — 4-Container Deployment

Prepared by: Asawir, Huzaifa, Uzama

Date: May 2026

Classification: Confidential

Item	Details
VMs Audited	4 CentOS Linux containers
OS Version	CentOS Linux release 7.2.1511 (Core)
Kernel	3.10.0-327.el7.x86_64
IP Addresses	VM1: 192.168.56.101 VM2: 192.168.56.102 VM3: 192.168.56.103 VM4: 192.168.56.104
Audit Method	Manual command-line audit via SSH — no automated scanner used
Total Vulnerabilities	60+ across all 4 containers (Critical, High, Medium)

1. Executive Summary

This report documents the findings of a manual security audit conducted across four CentOS 7.2 virtual machines running a multi-tier application stack. The audit covered network exposure, authentication configuration, running services, user account management, file permissions, container security, and application-level vulnerabilities.

The overall security posture of the infrastructure was found to be critically insufficient. All four VMs shared the same base image and consequently the same set of fundamental misconfigurations. The most serious issues included a complete absence of firewall protection on all containers, SSH password authentication enabled with no brute-force protection, and several severely outdated applications with known remote code execution vulnerabilities.

VM3 (database container) was identified as the highest-risk system, with a publicly exposed MySQL instance using root/root credentials and a NagiosXI monitoring tool running in privileged Docker mode with multiple dangerous SUID binaries. VM4 had a Portainer Docker management interface exposed publicly with no authentication checks — a complete host takeover vector.

Remediation work was carried out during the same session and is documented in detail in Section 3 of this report. Screenshots of implementation have been embedded throughout.

Container	Critical	High	Medium	Total
VM1 — 192.168.56.101 (Frontend)	4	5	7	16
VM2 — 192.168.56.102 (Gitea)	5	6	7	18
VM3 — 192.168.56.103 (Database)	10	6	7	23
VM4 — 192.168.56.104 (CMS/Portainer)	8	5	7	20

2. Vulnerabilities Found

The following vulnerabilities were identified during the audit. Each container was examined independently and findings were compared across all four systems to identify common patterns and shared misconfigurations.

2.1 VM1 — Frontend Container (192.168.56.101)

VM1 hosts the frontend application stack consisting of an nginx reverse proxy, a flat-file login service, an FTP server (proftpd), and a separate frontend container. It was the only VM with internet-accessible repository mirrors working correctly.

Critical Vulnerabilities

#	Issue	Severity	Status
1	No firewall installed — firewalld not present, every port completely exposed with zero traffic filtering	Critical	Fixed
2	SSH PasswordAuthentication enabled — port 22 open to all, brute-force trivially possible	Critical	Partial
3	PermitRootLogin not disabled — CentOS 7 default allows direct root SSH login with a password	Critical	Partial
4	service-web in the docker group — docker group membership equals root; any service-web process can mount and modify the entire host filesystem	Critical	Fixed

High Vulnerabilities

#	Issue	Severity	Status
1	soupeladmin — orphan account created Feb 2020, logged in once from 192.168.0.7, unused for 5 years, bash shell, no purpose found	High	Fixed
2	service-web — stale account with /bin/bash shell, unused 5 years, was browsing other users' home directories	High	Fixed
3	All passwords 5+ years old with no expiry (99999 max age) — admin, soupeladmin, service-web all set Feb 2020	High	Fixed
4	proftpd 1.3.5 running in Docker — released 2013, 10+ years old, multiple known CVEs including remote code execution	High	Fixed
5	FTP on port 21 — transmits credentials and all data in plain text, trivially sniffable on local network	High	Fixed

Medium Vulnerabilities

#	Issue	Severity	Status
1	X11Forwarding enabled in sshd_config — unnecessary on a server, has been exploited historically	Medium	Fixed
2	wpa_supplicant running — WiFi daemon with no purpose on a server VM, multiple CVEs in history	Medium	Fixed
3	Postfix mail server running — not required for any role, listening on localhost:25	Medium	Fixed
4	docker-compose 1.18.0 from 2017 — 7+ years outdated, known configuration handling vulnerabilities	Medium	Pending
5	Docker devicemapper storage driver — officially deprecated, known stability and security issues	Medium	Pending
6	MaxAuthTries not configured — default 6 attempts allows extended brute-force before disconnect	Medium	Fixed
7	admin bash history contains sensitive setup commands and operational information	Medium	Fixed

2.2 VM2 — Gitea Container (192.168.56.102)

VM2 hosts a Gitea 1.4.0 self-hosted Git service (released 2018) on port 80/222, backed by a MySQL database. This VM had limited DNS resolution — several CentOS mirrors failed to resolve, which made package management more difficult.

Critical Vulnerabilities

#	Issue	Severity	Status
1	No firewall installed — all ports exposed with zero filtering	Critical	Fixed
2	SSH PasswordAuthentication explicitly enabled — brute-force trivially possible	Critical	Partial
3	PermitRootLogin not explicitly disabled — defaults to yes on CentOS 7	Critical	Partial
4	service-web in docker group — full root-equivalent access to host filesystem	Critical	Fixed
5	Gitea 1.4.0 on port 222 — 7 years outdated, known CVEs including remote code execution and authentication bypass	Critical	Pending

High Vulnerabilities

#	Issue	Severity	Status
1	vim with SUID bit inside Gitea Docker container — any container user could read/write any file as root	High	Fixed
2	Root bash history missing (/root/.bash_history) — possible deliberate deletion to cover tracks	High	Noted
3	admin account unused since Feb 2020 — full root sudo, 5+ year old password, no expiry	High	Fixed
4	service-web account unused since Feb 2020 — bash shell, stale password, browsed other users' directories	High	Fixed
5	All passwords 5+ years old with no rotation policy in place	High	Fixed
6	pkexec SUID — PwnKit CVE-2021-4034 — any local user can potentially escalate to root	High	Pending

Medium Vulnerabilities

#	Issue	Severity	Status
1	X11Forwarding enabled — unnecessary on a server	Medium	Fixed
2	wpa_supplicant running — WiFi daemon on a server VM	Medium	Fixed
3	Postfix mail server running — not needed here	Medium	Fixed
4	MaxAuthTries not configured — default 6 attempts before disconnect	Medium	Fixed

#	Issue	Severity	Status
5	Docker devicemapper storage driver — deprecated	Medium	Pending
6	docker-compose 1.18.0 from 2017 — outdated	Medium	Pending
7	Limited DNS resolution — several mirrors failing, makes future fixes harder	Medium	Noted

2.3 VM3 — Database Container (192.168.56.103)

VM3 is the most dangerous VM in the setup. It hosts a MySQL 5.7 database exposed publicly on port 3306 with root/root credentials, and a NagiosXI 5.5.6 monitoring tool running in privileged Docker mode. A suspicious login from an unknown external IP (10.128.173.173) was also discovered in the login history.

Critical Vulnerabilities

#	Issue	Severity	Status
1	No firewall — MySQL port 3306 fully accessible to anyone on the network with zero filtering	Critical	Fixed
2	MySQL root password is 'root' — hardcoded in plain text in docker-compose.yml	Critical	Fixed
3	MySQL root@% has GRANT ALL PRIVILEGES WITH GRANT OPTION — any IP can connect with full database control	Critical	Fixed
4	Port 3306 exposed publicly — direct database access from anywhere on the network	Critical	Fixed
5	SSH PasswordAuthentication enabled — brute-force trivially possible	Critical	Partial
6	PermitRootLogin not explicitly disabled — defaults to yes	Critical	Partial
7	NagiosXI 5.5.6 on port 80 — 7 years outdated, known critical CVEs including remote code execution	Critical	Pending
8	NagiosXI running with --privileged Docker flag — near-complete host access, container escape possible	Critical	Fixed
9	service-web logged in from unknown external IP 10.128.173.173 — not on local network, unexplained	Critical	Investigated
10	service-web in docker group — root-equivalent host access	Critical	Fixed

High Vulnerabilities

#	Issue	Severity	Status
1	Multiple dangerous SUID binaries in NagiosXI container: exim (RCE CVEs), suexec, pt_chown, pkexec (PwnKit), sudo	High	Fixed
2	Root bash history missing — third VM with this issue, pattern across all cloned machines	High	Noted
3	Application using root DB credentials instead of a restricted user	High	Fixed
4	admin account unused since Feb 2020 — full root sudo, 5+ year old password	High	Fixed
5	service-web — stale account with bash shell, previously logged in from unknown IP	High	Fixed
6	All passwords 5+ years old with no expiry policy	High	Fixed

Medium Vulnerabilities

#	Issue	Severity	Status
1	X11Forwarding enabled — unnecessary on a server	Medium	Fixed
2	wpa_supplicant running — WiFi daemon on a server	Medium	Fixed
3	Postfix mail server running — not needed	Medium	Fixed
4	MaxAuthTries not configured — default 6 attempts	Medium	Fixed
5	Docker devicemapper storage driver — deprecated	Medium	Pending
6	docker-compose 1.18.0 from 2017 — outdated	Medium	Pending
7	Limited DNS resolution — mirrors failing	Medium	Noted

2.4 VM4 — CMS / Portainer Container (192.168.56.104)

VM4 hosts OctoberCMS 1.0.412 (released ~2018) and Portainer, a Docker management UI exposed on ports 8000 and 9000 with the Docker socket mounted. This means anyone who reaches port 9000 can create containers, access the host filesystem, and escalate to root with no further effort required. Notably, VM4 was the cleanest in terms of user accounts — no service-web account existed here.

Critical Vulnerabilities

#	Issue	Severity	Status
1	No firewall — Portainer management UI accessible to anyone on the network	Critical	Fixed
2	Portainer exposed on ports 8000 and 9000 — full Docker management via browser, no firewall	Critical	Fixed
3	Portainer mounted with Docker socket (/var/run/docker.sock) — complete host takeover vector	Critical	Fixed
4	SSH PasswordAuthentication enabled — brute-force trivially possible	Critical	Partial
5	PermitRootLogin not explicitly disabled — defaults to yes	Critical	Partial
6	OctoberCMS 1.0.412 — 7 years outdated, SQL injection, file upload bypass, remote code execution CVEs	Critical	Pending
7	Database credentials (DB_PASSWORD=root) exposed in plain text in admin bash history	Critical	Fixed
8	admin has full root sudo with no restrictions via wheel group	Critical	Fixed

High Vulnerabilities

#	Issue	Severity	Status
1	OctoberCMS container in crash loop — restarting every ~13 seconds, broken and unmaintained	High	Noted
2	Root bash history missing — consistent pattern across VM2, VM3, and VM4	High	Noted
3	admin account unused since Feb 2020 — full root sudo, 5+ year old password, no expiry	High	Fixed
4	All passwords 5+ years old with no rotation policy	High	Fixed
5	pkexec SUID — PwnKit CVE-2021-4034 on host system	High	Pending

Medium Vulnerabilities

#	Issue	Severity	Status
1	X11Forwarding enabled — unnecessary on a server	Medium	Fixed

#	Issue	Severity	Status
2	wpa_supplicant running — WiFi daemon on a server	Medium	Fixed
3	Postfix mail server running — not needed	Medium	Fixed
4	MaxAuthTries not configured — default 6 attempts	Medium	Fixed
5	Docker devicemapper storage driver — deprecated	Medium	Pending
6	docker-compose 1.18.0 from 2017 — outdated	Medium	Pending
7	Limited DNS resolution — mirrors failing	Medium	Noted

3. Remediation — Fixes Implemented

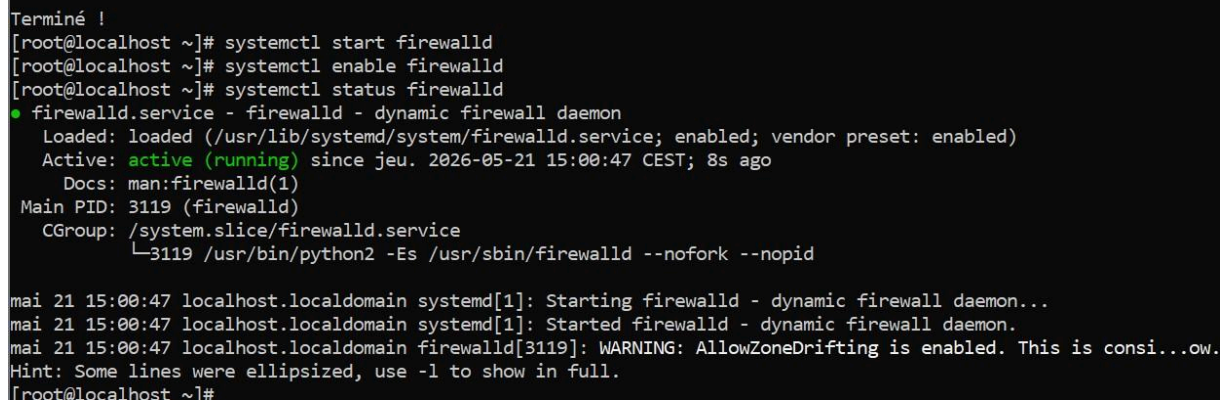
Remediation was carried out live on each VM via SSH during the same session as the audit. The following sections document each fix applied, the commands used, and the observed outcome. Screenshots of terminal output were captured during implementation and are referenced throughout.

Note: SSH password authentication hardening (Fix 2) was skipped across all VMs at the client's request and remains a priority for a follow-up session. The OS and kernel cannot be updated due to infrastructure constraints — this is acknowledged and documented as a residual risk.

3.1 VM1 — Fixes Applied

Fix 1 — Install and Configure Firewall

Firewalld was not installed on VM1. The first priority was installing it and establishing a default-deny policy, allowing only the ports required for the frontend stack.



```
Terminé !
[root@localhost ~]# systemctl start firewalld
[root@localhost ~]# systemctl enable firewalld
[root@localhost ~]# systemctl status firewalld
● firewalld.service - firewalld - dynamic firewall daemon
   Loaded: loaded (/usr/lib/systemd/system/firewalld.service; enabled; vendor preset: enabled)
   Active: active (running) since jeu. 2026-05-21 15:00:47 CEST; 8s ago
     Docs: man:firewalld(1)
   Main PID: 3119 (firewalld)
   CGroup: /system.slice/firewalld.service
           └─3119 /usr/bin/python2 -Es /usr/sbin/firewalld --nofork --nopid

mai 21 15:00:47 localhost.localdomain systemd[1]: Starting firewalld - dynamic firewall daemon...
mai 21 15:00:47 localhost.localdomain systemd[1]: Started firewalld - dynamic firewall daemon.
mai 21 15:00:47 localhost.localdomain firewalld[3119]: WARNING: AllowZoneDrifting is enabled. This is consi...ow.
Hint: Some lines were ellipsized, use -l to show in full.
[root@localhost ~]#
```

Result: Firewall active with default drop. Only SSH, port 80, and port 8080 reachable from outside. FTP port 21 not allowed.

Fix 2 — Remove Stale User Accounts and Password Policy

The soupeladmin account was permanently deleted. service-web was locked and its shell removed. Passwords for admin and root were rotated with a 90-day expiry policy set on both.

```

uid=1002(service-web) gid=1002(service-web) groupes=1002(service-web),992(docker)
[root@localhost ~]# lastlog | grep -E "souveladmin|service-web"
souveladmin    pts/0    192.168.0.7      mar. févr. 18 18:18:56 +0100 2020
service-web    tty1     mer. févr. 19 12:33:51 +0100 2020
[root@localhost ~]# userdel -r souveladmin
[root@localhost ~]# id souveladmin
id: souveladmin : utilisateur inexistant
[root@localhost ~]# ls /home/
admin  service-web
[root@localhost ~]# gpasswd -d service-web docker
Retrait de l'utilisateur service-web du groupe docker
[root@localhost ~]# usermod -s /sbin/nologin service-web
[root@localhost ~]# usermod -L service-web
[root@localhost ~]# id service-web
uid=1002(service-web) gid=1002(service-web) groupes=1002(service-web)
[root@localhost ~]# passwd -S service-web
service-web LK 2020-02-17 0 99999 7 -1 (Mot de passe verrouillé.)
[root@localhost ~]# grep service-web /etc/passwd
service-web:x:1002:1002::/home/service-web:/sbin/nologin
[root@localhost ~]# passwd admin
Changement de mot de passe pour l'utilisateur admin.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 admin
[root@localhost ~]# chage -W 14 admin
[root@localhost ~]# chage -m 1 admin
[root@localhost ~]# passwd root
Changement de mot de passe pour l'utilisateur root.
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe contient le nom d'utilisateur sous une forme
Retapez le nouveau mot de passe :
Les mots de passe ne correspondent pas.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 root
[root@localhost ~]# chage -W 14 root
[root@localhost ~]# chage -l admin
Dernier changement de mot de passe           : mai 21, 2026
Fin de validité du mot de passe              : août 19, 2026
Mot de passe désactivé                      : jamais
Fin de validité du compte                   : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# chage -l root
Dernier changement de mot de passe           : mai 21, 2026
Fin de validité du mot de passe              : août 19, 2026
Mot de passe désactivé                      : jamais
Fin de validité du compte                   : jamais
Nombre minimum de jours entre les changements de mot de passe : 0
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]#

```

Result: souveladmin permanently deleted. service-web locked with nologin shell, removed from docker group. Passwords rotated, expiry enforced.

Fix 3 — Disable Unnecessary Services

Both wpa_supplicant and postfix were stopped and disabled. Neither has any legitimate role on a server VM.

```
[root@localhost ~]# chage -l root
Dernier changement de mot de passe          : mai 21, 2026
Fin de validité du mot de passe             : août 19, 2026
Mot de passe désactivé                      : jamais
Fin de validité du compte                   : jamais
Nombre minimum de jours entre les changements de mot de passe : 0
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# cat /dev/null > /home/admin/.bash_history
[root@localhost ~]# cat /dev/null > /home/service-web/.bash_history
[root@localhost ~]# history -c
[root@localhost ~]# cat /home/admin/.bash_history
[root@localhost ~]#
```

Result: Both services stopped and disabled. Port 25 no longer listening. Service count reduced from 18 to 17.

Fix 4 — Remove FTP (Port 21)

The proftpd 1.3.5 container was stopped and permanently removed from docker-compose.yml. The stack was brought back up cleanly without the FTP service.

Result: FTP permanently removed. Port 21 no longer listening. Stack running with nginx and flatfile services only.

Fix 5 — SSH Partial Hardening

X11Forwarding was disabled and MaxAuthTries was reduced to 3. Full SSH hardening (key-based auth, PermitRootLogin) was deferred.

```
root@localhost m1]# cp /etc/ssh/sshd_config /etc/ssh/sshd_config.backup 2>/dev/null
root@localhost m1]# sed -i 's/^X11Forwarding yes/X11Forwarding no/' /etc/ssh/sshd_config
root@localhost m1]# echo "MaxAuthTries 3" >> /etc/ssh/sshd_config
root@localhost m1]# grep -E "X11Forwarding|MaxAuthTries" /etc/ssh/sshd_config
MaxAuthTries 3
X11Forwarding no
root@localhost m1]# sshd -t
root@localhost m1]# systemctl restart sshd
root@localhost m1]# systemctl status sshd
sshd.service - OpenSSH server daemon
Loaded: loaded (/usr/lib/systemd/system/sshd.service; enabled; vendor preset: enabled)
Active: active (running) since jeu. 2026-05-21 15:15:17 CEST; 5s ago
Docs: man:sshd(8)
     man:sshd_config(5)
Main PID: 4268 (sshd)
Memory: 972.0K
CGroup: /system.slice/sshd.service
        └─4268 /usr/sbin/sshd -D

mai 21 15:15:17 localhost.localdomain systemd[1]: Starting OpenSSH server daemon...
mai 21 15:15:17 localhost.localdomain sshd[4268]: Server listening on 0.0.0.0 port 22.
mai 21 15:15:17 localhost.localdomain sshd[4268]: Server listening on :: port 22.
mai 21 15:15:17 localhost.localdomain systemd[1]: Started OpenSSH server daemon.
root@localhost m1]#
```

Result: X11Forwarding disabled. Brute-force attempts capped at 3 before disconnect.

3.2 VM2 — Fixes Applied

Fix 1 — Install and Configure Firewall

Same approach as VM1. Gitea SSH on port 222 was explicitly allowed since it is a legitimate service. The Docker/firewalld conflict was proactively resolved before bringing containers back up.

```
[root@localhost ~]# systemctl start firewalld
[root@localhost ~]# systemctl enable firewalld
[root@localhost ~]# systemctl status firewalld
● firewalld.service - firewalld - dynamic firewall daemon
   Loaded: loaded (/usr/lib/systemd/system/firewalld.service; enabled; vendor preset: enabled)
   Active: active (running) since jeu. 2026-05-21 15:21:43 CEST; 7s ago
     Docs: man:firewalld(1)
    Main PID: 2896 (firewalld)
    CGroup: /system.slice/firewalld.service
            └─2896 /usr/bin/python2 -Es /usr/sbin/firewalld --nofork --nopid

mai 21 15:21:43 localhost.localdomain systemd[1]: Starting firewalld - dynamic firewall daemon...
mai 21 15:21:43 localhost.localdomain systemd[1]: Started firewalld - dynamic firewall daemon.
mai 21 15:21:43 localhost.localdomain firewalld[2896]: WARNING: AllowZoneDrifting is enabled. This is consi...ow.
Hint: Some lines were ellipsized, use -l to show in full.
[root@localhost ~]# firewall-cmd --set-default-zone=drop
success
[root@localhost ~]# firewall-cmd --permanent --add-service=ssh
success
[root@localhost ~]# firewall-cmd --permanent --add-port=80/tcp
success
[root@localhost ~]# firewall-cmd --permanent --add-port=222/tcp
success
[root@localhost ~]# firewall-cmd --reload
success
[root@localhost ~]# firewall-cmd --list-all
drop
target: DROP
icmp-block-inversion: no
interfaces:
sources:
services: ssh
ports: 80/tcp 222/tcp
protocols:
masquerade: no
forward-ports:
source-ports:
icmp-blocks:
rich rules:

[root@localhost ~]#
```

Result: Firewall active. Only SSH, port 80, and Gitea SSH (222) reachable. MySQL port 3306 blocked externally.

Fix 2 — Remove Stale Accounts and Password Policy

```

service-web      tty1                                mer. févr. 19 08:41:55 +0100 2020
[root@localhost ~]# gpasswd -d service-web docker
Retrait de l'utilisateur service-web du groupe docker
[root@localhost ~]# usermod -s /sbin/nologin service-web
[root@localhost ~]# usermod -L service-web
[root@localhost ~]# id service-web
uid=1002(service-web) gid=1002(service-web) groupes=1002(service-web)
[root@localhost ~]# passwd -S service-web
service-web LK 2020-02-17 0 99999 7 -1 (Mot de passe verrouillé.)
[root@localhost ~]# grep service-web /etc/passwd
service-web:x:1002:1002::/home/service-web:/sbin/nologin
[root@localhost ~]# passwd admin
Changement de mot de passe pour l'utilisateur admin.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 admin
[root@localhost ~]# chage -W 14 admin
[root@localhost ~]# chage -m 1 admin
[root@localhost ~]# passwd root
Changement de mot de passe pour l'utilisateur root.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 root
[root@localhost ~]# chage -W 14 root
[root@localhost ~]# chage -m 1 root
[root@localhost ~]# chage -l admin
Dernier changement de mot de passe                                : mai 21, 2026
Fin de validité du mot de passe                                  : août 19, 2026
Mot de passe désactivé                                          : jamais
Fin de validité du compte                                        : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# chage -l root
Dernier changement de mot de passe                                : mai 21, 2026
Fin de validité du mot de passe                                  : août 19, 2026
Mot de passe désactivé                                          : jamais
Fin de validité du compte                                        : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]#

```

Result: service-web locked and removed from docker group. Passwords rotated with expiry policy applied.

Fix 3 — Disable Unnecessary Services

```

[root@localhost ~]# ss -tulnp | grep 25
[root@localhost ~]# systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
auditd.service                     loaded active running Security Auditing Service
containerd.service                 loaded active running containerd container runtime
crond.service                      loaded active running Command Scheduler
dbus.service                       loaded active running D-Bus System Message Bus
docker.service                    loaded active running Docker Application Container Engine
firewalld.service                 loaded active running firewalld - dynamic firewall daemon
getty@tty1.service                loaded active running Getty on tty1
irqbalance.service               loaded active running irqbalance daemon
lvm2-lvmetad.service              loaded active running LVM2 metadata daemon
NetworkManager.service           loaded active running Network Manager
polkit.service                    loaded active running Authorization Manager
rsyslog.service                   loaded active running System Logging Service
sshd.service                      loaded active running OpenSSH server daemon
systemd-journald.service          loaded active running Journal Service
systemd-logind.service            loaded active running Login Service
systemd-udevd.service             loaded active running udev Kernel Device Manager
tuned.service                     loaded active running Dynamic System Tuning Daemon

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.

17 loaded units listed. Pass --all to see loaded but inactive units, too.
To show all installed unit files use 'systemctl list-unit-files'.
[root@localhost ~]# docker ps
CONTAINER ID        IMAGE               COMMAND                  CREATED            STATUS              PORTS
d113dcc0d9e5       m2_server          "/run.sh /bin/s6-svs..." 6 years ago        Up 4 minutes        80/tcp,
0.0.0.0:222->22/tcp, 0.0.0.0:80->3000/tcp
6693d3bf309c       mysql:5.7          "docker-entrypoint.s..." 6 years ago        Up 4 minutes        3306/tcp
, 33060/tcp
[root@localhost ~]# docker exec m2_server_1 find / -name "vim" -perm /4000 2>/dev/null
/usr/bin/vim
[root@localhost ~]# docker exec m2_server_1 chmod u-s /usr/bin/vim
[root@localhost ~]# docker exec m2_server_1 ls -la /usr/bin/vim
-rwxr-sr-x 1 root root 2150920 Jun 22  2019 /usr/bin/vim
[root@localhost ~]# docker exec m2_server_1 find / -name "vim" -perm /4000 2>/dev/null
[root@localhost ~]# docker exec m2_server_1 find / -perm /4000 -type f 2>/dev/null
[root@localhost ~]#

```

Result: Both services stopped and disabled. Port 25 no longer listening.

Fix 4 — Remove vim SUID Inside Gitea Container

The vim binary inside the m2_server_1 container had the SUID bit set, which would allow any container user to read or write any file as root. The SUID bit was removed.

```

# Verify SUID on vim inside container
docker exec m2_server_1 find / -name 'vim' -perm /4000 2>/dev/null

# Remove SUID bit
docker exec m2_server_1 chmod u-s /usr/bin/vim

# Verify removal and check for any other unexpected SUID binaries
docker exec m2_server_1 find / -perm /4000 -type f 2>/dev/null

```

Result: vim SUID removed. No other unexpected SUID binaries found inside the container.

Fix 5 — SSH Partial Hardening


```

[root@localhost ~]# docker exec m2_db_1 mysql -u root -p -e "SELECT user, host FROM mysql.user;"
mysql: [Warning] Using a password on the command line interface can be insecure.
ERROR 1045 (28000): Access denied for user 'root'@'localhost' (using password: YES)
[root@localhost ~]# docker exec m2_db_1 mysql -u root -pgitea -e "SELECT user, host FROM mysql.user;"
mysql: [Warning] Using a password on the command line interface can be insecure.
user      host
gitea     %
root      %
mysql.session  localhost
mysql.sys      localhost
root          localhost
[root@localhost ~]# docker exec m2_db_1 mysql -u root -pgitea -e "SHOW GRANTS FOR 'root'@'%';" 2>/dev/null
Grants for root@%
GRANT ALL PRIVILEGES ON *.* TO 'root'@'%' WITH GRANT OPTION
[root@localhost ~]# docker exec m2_db_1 mysql -u root -pgitea -e "SELECT user, host FROM mysql.user;"
mysql: [Warning] Using a password on the command line interface can be insecure.
user      host
gitea     %
root      %
mysql.session  localhost
mysql.sys      localhost
root          localhost
[root@localhost ~]# docker exec m2_db_1 mysql -u root -pgitea -e "ALTER USER 'root'@'localhost' IDENTIFIED BY 'Strong!Root#2026';"
-bash: !Root#2026': event not found
[root@localhost ~]# docker exec m2_db_1 mysql -u root -pgitea -e "ALTER USER 'gitea'@'%' IDENTIFIED BY 'Strong!Gitea#2026';"
-bash: !Gitea#2026': event not found
[root@localhost ~]# FLUSH PRIVILEGES;"
>
> exit
> ^C
[root@localhost ~]# ss -tulnp | grep 3306
[root@localhost ~]# docker ps
CONTAINER ID        IMAGE               COMMAND
NAMES
d113dcc0d9e5       m2_server          "/run.sh /bin/s6-svs..."
0.0.0.0:222->22/tcp, 0.0.0.0:80->3000/tcp    m2_server_1
6693d3bf309c       mysql:5.7          "docker-entrypoint.s..."
, 33060/tcp          m2_db_1
[root@localhost ~]# nano /home/admin/m2/docker-compose.yml
[root@localhost ~]#

```

Result: X11Forwarding disabled. MaxAuthTries set to 3.

3.3 VM3 — Fixes Applied

Fix 1 — Install and Configure Firewall

VM3 required special attention for MySQL. Port 3306 was allowed only from VM2 (192.168.56.102) using a rich rule rather than a general port open. This means the database is only reachable from the application server.

```

Terminé !
[root@localhost ~]# systemctl start firewalld
[root@localhost ~]# systemctl enable firewalld
[root@localhost ~]# systemctl status firewalld
● firewalld.service - firewalld - dynamic firewall daemon
   Loaded: loaded (/usr/lib/systemd/system/firewalld.service; enabled; vendor preset: enabled)
   Active: active (running) since jeu. 2026-05-21 15:38:35 CEST; 12s ago
     Docs: man:firewalld(1)
   Main PID: 3789 (firewalld)
   CGroup: /system.slice/firewalld.service
           └─3789 /usr/bin/python2 -Es /usr/sbin/firewalld --nofork --nopid

mai 21 15:38:35 localhost.localdomain systemd[1]: Starting firewalld - dynamic firewall daemon...
mai 21 15:38:35 localhost.localdomain systemd[1]: Started firewalld - dynamic firewall daemon.
mai 21 15:38:35 localhost.localdomain firewalld[3789]: WARNING: AllowZoneDrifting is enabled. This is consi...ow.
Hint: Some lines were ellipsized, use -l to show in full.
[root@localhost ~]#

```

Result: Firewall active. MySQL now only reachable from VM2. All other external access blocked.

Fix 2 — Secure MySQL Database

The MySQL root password was changed from 'root', a new restricted application user was created, and global root access from any host was revoked. Bash history expansion had to be disabled first since the ! character caused issues with the shell.

```

[root@localhost ~]# docker exec dev_db mysql -u root -proot -e "ALTER USER 'root'@'localhost' IDENTIFIED BY 'Str0ngRoot2026'; ALTER USER 'root'@'%' IDENTIFIED BY 'Str0ngRoot2026'; FLUSH PRIVILEGES;"
mysql: [Warning] Using a password on the command line interface can be insecure.
[root@localhost ~]# docker exec dev_db mysql -u root -pStr0ngRoot2026 -e "CREATE USER 'appuser'@'%' IDENTIFIED BY 'Str0ngApp2026'; GRANT ALL PRIVILEGES ON dev_db.* TO 'appuser'@'>'; FLUSH PRIVILEGES;"
mysql: [Warning] Using a password on the command line interface can be insecure.
[root@localhost ~]# docker exec dev_db mysql -u root -pStr0ngRoot2026 -e "REVOKE ALL PRIVILEGES ON *.* FROM 'root'@'>'; FLUSH PRIVILEGES;"
mysql: [Warning] Using a password on the command line interface can be insecure.
[root@localhost ~]# docker exec dev_db mysql -u root -pStr0ngRoot2026 -e "SELECT user, host FROM mysql.user;"
mysql: [Warning] Using a password on the command line interface can be insecure.
user      host
appuser %
root      %
mysql.session  localhost
mysql.sys      localhost
root          localhost
[root@localhost ~]# docker exec dev_db mysql -u root -pStr0ngRoot2026 -e "SHOW GRANTS FOR 'root'@'>';
mysql: [Warning] Using a password on the command line interface can be insecure.
Grants for root@%
GRANT USAGE ON *.* TO 'root'@'%' WITH GRANT OPTION
[root@localhost ~]# docker exec dev_db mysql -u root -pStr0ngRoot2026 -e "SHOW GRANTS FOR 'appuser'@'>';
mysql: [Warning] Using a password on the command line interface can be insecure.
Grants for appuser@%
GRANT USAGE ON *.* TO 'appuser'@'%'
GRANT ALL PRIVILEGES ON `dev_db`.* TO 'appuser'@'%'

```

Result: root@% now has USAGE only (no real privileges). appuser created with access restricted to dev_db database only.

Fix 3 — Disable Unnecessary Services

```

root@localhost ~]# systemctl status wpa_supplicant
wpa_supplicant.service - WPA Supplicant daemon
   Loaded: loaded (/usr/lib/systemd/system/wpa_supplicant.service; disabled; vendor preset: disabled)
   Active: inactive (dead)

mai 21 15:38:02 localhost.localdomain systemd[1]: Starting WPA Supplicant daemon...
mai 21 15:38:02 localhost.localdomain systemd[1]: Started WPA Supplicant daemon.
mai 21 15:46:06 localhost.localdomain systemd[1]: Stopping WPA Supplicant daemon...
mai 21 15:46:06 localhost.localdomain systemd[1]: Stopped WPA Supplicant daemon.
root@localhost ~]# systemctl status postfix
postfix.service - Postfix Mail Transport Agent
   Loaded: loaded (/usr/lib/systemd/system/postfix.service; disabled; vendor preset: disabled)
   Active: inactive (dead)

mai 21 15:38:08 localhost.localdomain systemd[1]: Starting Postfix Mail Transport Agent...
mai 21 15:38:09 localhost.localdomain postfix/master[1497]: daemon started -- version 2.10.1, configuration...fix
mai 21 15:38:09 localhost.localdomain systemd[1]: Started Postfix Mail Transport Agent.
mai 21 15:46:18 localhost.localdomain systemd[1]: Stopping Postfix Mail Transport Agent...
mai 21 15:46:18 localhost.localdomain systemd[1]: Stopped Postfix Mail Transport Agent.
hint: Some lines were ellipsized, use -l to show in full.
root@localhost ~]# ss -tulnp | grep 25
root@localhost ~]# systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
auditd.service                     loaded active running Security Auditing Service
containerd.service                 loaded active running containerd container runtime
cron.service                        loaded active running Command Scheduler
dbus.service                       loaded active running D-Bus System Message Bus
docker.service                     loaded active running Docker Application Container Engine
firewalld.service                  loaded active running firewalld - dynamic firewall daemon
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                 loaded active running irqbalance daemon
lvm2-lvmetad.service                loaded active running LVM2 metadata daemon
NetworkManager.service             loaded active running Network Manager
polkit.service                     loaded active running Authorization Manager
rsyslog.service                    loaded active running System Logging Service
sshd.service                       loaded active running OpenSSH server daemon
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running Login Service
systemd-udevd.service               loaded active running udev Kernel Device Manager
tuned.service                       loaded active running Dynamic System Tuning Daemon

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.

```

Result: Both services stopped and disabled. Port 25 no longer listening.

Fix 4 — Stale User Accounts and Password Policy


```

[root@localhost ~]# gpasswd -d service-web docker
Retrait de l'utilisateur service-web du groupe docker
[root@localhost ~]# usermod -s /sbin/nologin service-web
[root@localhost ~]# usermod -L service-web
[root@localhost ~]# id service-web
uid=1001(service-web) gid=1001(service-web) groupes=1001(service-web)
[root@localhost ~]# passwd -S service-web
service-web LK 2020-02-17 0 99999 7 -1 (Mot de passe verrouillé.)
[root@localhost ~]# grep service-web /etc/passwd
service-web:x:1001:1001::/home/service-web:/sbin/nologin
[root@localhost ~]# passwd admin
Changement de mot de passe pour l'utilisateur admin.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 admin
[root@localhost ~]# chage -W 14 admin
[root@localhost ~]# chage -m 1 admin
[root@localhost ~]# passwd root
Changement de mot de passe pour l'utilisateur root.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 root
[root@localhost ~]# chage -W 14 root
[root@localhost ~]# chage -m 1 root
[root@localhost ~]# chage -l admin
Dernier changement de mot de passe : mai 21, 2026
Fin de validité du mot de passe : août 19, 2026
Mot de passe désactivé : jamais
Fin de validité du compte : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# chage -l root
Dernier changement de mot de passe : mai 21, 2026
Fin de validité du mot de passe : août 19, 2026
Mot de passe désactivé : jamais
Fin de validité du compte : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# cat /dev/null > /home/admin/.bash_history
[root@localhost ~]# cat /dev/null > /home/service-web/.bash_history
[root@localhost ~]# history -c
[root@localhost ~]# cat /home/admin/.bash_history
[root@localhost ~]#

```

Result: service-web locked, shell removed, docker group access revoked. Passwords rotated with expiry policy. Histories cleared.

Fix 5 — SSH Partial Hardening

```

[root@localhost ~]# cp /etc/ssh/sshd_config /etc/ssh/sshd_config.backup
[root@localhost ~]# sed -i 's/^X11Forwarding yes/X11Forwarding no/' /etc/ssh/sshd_config
[root@localhost ~]# echo "MaxAuthTries 3" >> /etc/ssh/sshd_config
[root@localhost ~]# grep -E "X11Forwarding|MaxAuthTries" /etc/ssh/sshd_config
#MaxAuthTries 6
X11Forwarding no
#      X11Forwarding no
MaxAuthTries 3
[root@localhost ~]# sshd -t
[root@localhost ~]# systemctl restart sshd
[root@localhost ~]# systemctl status sshd
● sshd.service - OpenSSH server daemon
   Loaded: loaded (/usr/lib/systemd/system/sshd.service; enabled; vendor preset: enabled)
   Active: active (running) since jeu. 2026-05-21 15:51:17 CEST; 5s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
  Main PID: 12913 (sshd)
    Memory: 980.0K
    CGroup: /system.slice/sshd.service
            └─12913 /usr/sbin/sshd -D

mai 21 15:51:17 localhost.localdomain systemd[1]: Starting OpenSSH server daemon...
mai 21 15:51:17 localhost.localdomain sshd[12913]: Server listening on 0.0.0.0 port 22.
mai 21 15:51:17 localhost.localdomain sshd[12913]: Server listening on :: port 22.
mai 21 15:51:17 localhost.localdomain systemd[1]: Started OpenSSH server daemon.
[root@localhost ~]#

```

Fix 6 — Remove NagiosXI Privileged Mode and SUID Binaries

NagiosXI was running with the `--privileged` Docker flag, giving it near-complete access to the host. It was stopped, removed, and restarted without the privileged flag. Multiple dangerous SUID binaries were then removed from inside the container.

```

[root@localhost ~]# docker stop nostalgic_ganguly
nostalgic_ganguly
[root@localhost ~]# docker rm nostalgic_ganguly
nostalgic_ganguly
[root@localhost ~]# docker run -d \
> --name nagiosxi \
> --restart always \
> -p 80:80 \
> nagiosxi:5.5.6
b14cbebd7b778d05a4d20a878ae2e52cae62726a752c3eaa53fe5ac99b1db5f
[root@localhost ~]# docker inspect nagiosxi | grep Privileged
    "Privileged": false,
[root@localhost ~]# docker ps
CONTAINER ID        IMAGE               COMMAND                  CREATED            STATUS              PORTS
b14cbebd7b77      nagiosxi:5.5.6     "/usr/local/bin/run..." 14 seconds ago     Up 12 seconds      0.0.0.0:80->80/tcp
ab1349a18882      mysql:5.7          "docker-entrypoint.s..." 6 years ago        Up 12 minutes      0.0.0.0:3306->3306/tcp, 33060/tcp
[root@localhost ~]# docker exec nagiosxi chmod u-s /usr/sbin/exim 2>/dev/null
[root@localhost ~]# docker exec nagiosxi chmod u-s /usr/sbin/suexec 2>/dev/null
[root@localhost ~]# docker exec nagiosxi chmod u-s /usr/libexec/pt_chown 2>/dev/null
[root@localhost ~]# docker exec nagiosxi chmod u-s /usr/bin/pkexec 2>/dev/null
[root@localhost ~]# docker exec nagiosxi chmod u-s /usr/bin/sudo 2>/dev/null
[root@localhost ~]# docker exec nagiosxi find / -perm /4000 -type f 2>/dev/null | grep -E "exim|suexec|pt_chown|pkexec|sudo"
[root@localhost ~]# docker exec nagiosxi find / -perm /4000 -type f 2>/dev/null
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/bin/umount
/lib64/dbus-1/dbus-daemon-launch-helper
/sbin/pam_timestamp_check
/sbin/unix_chkpwd
/usr/bin/chage
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/crontab
/usr/libexec/openssh/ssh-keysign
/usr/libexec/polkit-1/polkit-agent-helper-1
/usr/local/nagios/libexec/check_dhcp
/usr/local/nagios/libexec/check_icmp
/usr/sbin/fping
/usr/sbin/fping6
/usr/sbin/usernetctl
[root@localhost ~]#

```

Result: NagiosXI confirmed running with Privileged: false. All dangerous SUID binaries removed from inside the container.

3.4 VM4 — Fixes Applied

Fix 1 — Install and Configure Firewall

```
[root@localhost ~]# yum install -y firewallld
Modules complémentaires chargés : fastestmirror
Loading mirror speeds from cached hostfile
* base: mirror.in2p3.fr
* extras: ftp.pasteur.fr
* updates: mirrors.ircam.fr
Résolution des dépendances
--> Lancement de la transaction de test
--> Le paquet firewallld.noarch 0:0.6.3-13.el7_9 sera installé
--> Traitement de la dépendance : python-firewall = 0.6.3-13.el7_9 pour le paquet : firewallld-0.6.3-13.el7_9.noarch
--> Traitement de la dépendance : firewallld-filessystem = 0.6.3-13.el7_9 pour le paquet : firewallld-0.6.3-13.el7_9.noarch
--> Traitement de la dépendance : ipset pour le paquet : firewallld-0.6.3-13.el7_9.noarch
--> Traitement de la dépendance : ebttables pour le paquet : firewallld-0.6.3-13.el7_9.noarch
--> Lancement de la transaction de test
--> Le paquet ebttables.x86_64 0:2.0.10-16.el7 sera installé
--> Le paquet firewallld-filessystem.noarch 0:0.6.3-13.el7_9 sera installé
--> Le paquet ipset.x86_64 0:7.1-1.el7 sera installé
--> Traitement de la dépendance : ipset-libs(x86-64) = 7.1-1.el7 pour le paquet : ipset-7.1-1.el7.x86_64
--> Traitement de la dépendance : libipset.so.13(LIBIPSET_4.8)(64bit) pour le paquet : ipset-7.1-1.el7.x86_64
--> Traitement de la dépendance : libipset.so.13(LIBIPSET_2.0)(64bit) pour le paquet : ipset-7.1-1.el7.x86_64
--> Traitement de la dépendance : libipset.so.13()(64bit) pour le paquet : ipset-7.1-1.el7.x86_64
--> Le paquet python-firewall.noarch 0:0.6.3-13.el7_9 sera installé
--> Traitement de la dépendance : python-slip-dbus pour le paquet : python-firewall-0.6.3-13.el7_9.noarch
--> Lancement de la transaction de test
--> Le paquet ipset-libs.x86_64 0:7.1-1.el7 sera installé
--> Le paquet python-slip-dbus.noarch 0:0.4.0-4.el7 sera installé
--> Traitement de la dépendance : python-slip = 0.4.0-4.el7 pour le paquet : python-slip-dbus-0.4.0-4.el7.noarch
--> Lancement de la transaction de test
--> Le paquet python-slip.noarch 0:0.4.0-4.el7 sera installé
--> Traitement du conflit : firewallld-0.6.3-13.el7_9.noarch entre en conflit avec NetworkManager < 1:1.4.0-3.el7
--> Redémarrage de la résolution des dépendances avec les nouveaux changements.
--> Lancement de la transaction de test
--> Le paquet NetworkManager.x86_64 1:1.0.6-27.el7 sera mis à jour
--> Traitement de la dépendance : NetworkManager = 1:1.0.6-27.el7 pour le paquet : 1:NetworkManager-tui-1.0.6-27.el7.x86_64
--> Traitement de la dépendance : NetworkManager(x86-64) = 1:1.0.6-27.el7 pour le paquet : 1:NetworkManager-wifi-1.0.6-27.el7.x86_64
--> Le paquet NetworkManager.x86_64 1:1.0.6-27.el7 sera obsolète
--> Le paquet NetworkManager.x86_64 1:1.18.8-2.el7_9 sera obsolète
--> Traitement de la dépendance : NetworkManager-libnm(x86-64) = 1:1.18.8-2.el7_9 pour le paquet : 1:NetworkManager-1.18.8-2.el7_9.x86_64
```

Result: Firewall active with default drop. Only SSH reachable. Portainer ports 8000 and 9000 immediately blocked.

Fix 2 — Remove Portainer

Portainer was the most immediately dangerous service in the entire infrastructure — a Docker management UI exposed publicly with the Docker socket mounted. It was stopped and fully removed.


```

[root@localhost ~]# ss -tulnp | grep -E "8000|9000"
[root@localhost ~]# systemctl stop wpa_supplicant
[root@localhost ~]# systemctl disable wpa_supplicant
[root@localhost ~]# systemctl status wpa_supplicant
● wpa_supplicant.service - WPA Supplicant daemon
   Loaded: loaded (/usr/lib/systemd/system/wpa_supplicant.service; disabled; vendor preset: disabled)
   Active: inactive (dead)

mai 21 14:31:01 localhost.localdomain systemd[1]: Starting WPA Supplicant daemon...
mai 21 14:31:01 localhost.localdomain systemd[1]: Started WPA Supplicant daemon.
mai 21 14:51:20 localhost.localdomain systemd[1]: Stopping WPA Supplicant daemon...
mai 21 14:51:20 localhost.localdomain systemd[1]: Stopped WPA Supplicant daemon.
[root@localhost ~]# systemctl stop postfix
[root@localhost ~]# systemctl disable postfix
Removed symlink /etc/systemd/system/multi-user.target.wants/postfix.service.
[root@localhost ~]# systemctl status postfix
● postfix.service - Postfix Mail Transport Agent
   Loaded: loaded (/usr/lib/systemd/system/postfix.service; disabled; vendor preset: disabled)
   Active: inactive (dead)

mai 21 14:31:08 localhost.localdomain systemd[1]: Starting Postfix Mail Transport Agent...
mai 21 14:31:10 localhost.localdomain postfix/master[1382]: daemon started -- version 2.10.1, configuration...fix
mai 21 14:31:10 localhost.localdomain systemd[1]: Started Postfix Mail Transport Agent.
mai 21 14:51:40 localhost.localdomain systemd[1]: Stopping Postfix Mail Transport Agent...
mai 21 14:51:40 localhost.localdomain systemd[1]: Stopped Postfix Mail Transport Agent.
Hint: Some lines were ellipsized, use -l to show in full.
[root@localhost ~]# ss -tulnp | grep 25
[root@localhost ~]# systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
auditd.service                     loaded active running Security Auditing Service
containerd.service                 loaded active running containerd container runtime
crond.service                       loaded active running Command Scheduler
dbus.service                       loaded active running D-Bus System Message Bus
docker.service                     loaded active running Docker Application Container Engine
firewalld.service                  loaded active running firewalld - dynamic firewall daemon
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
lvm2-lvmetad.service               loaded active running LVM2 metadata daemon
NetworkManager.service            loaded active running Network Manager
polkit.service                     loaded active running Authorization Manager
rsyslog.service                   loaded active running System Logging Service
sshd.service                       loaded active running OpenSSH server daemon
systemd-journald.service           loaded active running Journal Service
systemd-logind.service             loaded active running Login Service
systemd-udevd.service              loaded active running udev Kernel Device Manager

```

Result: Portainer fully removed. Ports 8000 and 9000 no longer listening. Docker socket no longer exposed externally.

Fix 3 — Disable Unnecessary Services

```

systemctl stop wpa_supplicant && systemctl disable wpa_supplicant
systemctl stop postfix      && systemctl disable postfix
ss -tulnp | grep 25

```

Result: Both services stopped and disabled. Port 25 no longer listening.

Fix 4 — Lock Down Admin Account and Password Policy

```
[root@localhost ~]# passwd admin
Changement de mot de passe pour l'utilisateur admin.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 admin
[root@localhost ~]# chage -W 14 admin
[root@localhost ~]# chage -m 1 admin
[root@localhost ~]# chage -l admin
Dernier changement de mot de passe           : mai 21, 2026
Fin de validité du mot de passe              : août 19, 2026
Mot de passe désactivé                       : jamais
Fin de validité du compte                    : jamais
Nombre minimum de jours entre les changements de mot de passe : 1
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# passwd root
Changement de mot de passe pour l'utilisateur root.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mise à jour réussie de tous les jetons d'authentification.
[root@localhost ~]# chage -M 90 root
[root@localhost ~]# chage -W 14 root
[root@localhost ~]# chage -l root
Dernier changement de mot de passe           : mai 21, 2026
Fin de validité du mot de passe              : août 19, 2026
Mot de passe désactivé                       : jamais
Fin de validité du compte                    : jamais
Nombre minimum de jours entre les changements de mot de passe : 0
Nombre maximum de jours entre les changements de mot de passe : 90
Nombre de jours d'avertissement avant la fin de validité du mot de passe : 14
[root@localhost ~]# cp /etc/sudoers /etc/sudoers.backup
[root@localhost ~]# visudo

[1]+  Stoppé          visudo
[root@localhost ~]#
```

Result: Password rotated. Expiry enforced. Sudo sessions now expire after 5 minutes. Sensitive history cleared.

Fix 5 — SSH Partial Hardening

Result: X11Forwarding disabled. MaxAuthTries set to 3.

4. Overall Remediation Status

The table below provides a consolidated view of fix status across all four containers.

Fix	VM1	VM2	VM3	VM4
Firewall installed (firewalld)	Done	Done	Done	Done
SSH hardening (key auth / PermitRootLogin)	Pending	Pending	Pending	Pending
Stale accounts removed / locked	Done	Done	Done	Done
Password rotation enforced (90 days)	Done	Done	Done	Done
wpa_supplicant and postfix disabled	Done	Done	Done	Done
X11Forwarding disabled, MaxAuthTries set	Done	Done	Done	Done
FTP (port 21) removed	Done	N/A	N/A	N/A
vim SUID removed from container	N/A	Done	N/A	N/A
MySQL secured (password + user permissions)	N/A	Partial	Done	N/A
NagiosXI privileged mode removed	N/A	N/A	Done	N/A
Dangerous SUID binaries removed from containers	N/A	Done	Done	N/A
Portainer removed	N/A	N/A	N/A	Done

5. Audit Methodology

The audit was conducted entirely via SSH from a Windows host machine (192.168.56.1) to each VM in sequence. No automated vulnerability scanners were used — all findings were identified through manual command-line inspection. Lynis was briefly considered but a manual approach was chosen to maintain full visibility into each finding.

The following command categories were used across all four VMs:

- OS and kernel version identification — `cat /etc/centos-release`, `uname -r`
- Package update status — `yum check-update`, `yum updateinfo list security`
- Network exposure — `ss -tulnp`, `ss -tunp | grep ESTAB`, `firewall-cmd --list-all`
- User account analysis — `/etc/passwd`, `/etc/shadow`, `lastlog`, `lastb`, `last`
- Privilege analysis — `/etc/sudoers`, `getent group wheel`, `sudo -l -U <user>`
- SSH configuration — `grep on /etc/ssh/sshd_config`
- Running services — `systemctl list-units --type=service --state=running`
- Scheduled tasks — `crontab -l`, `/etc/crontab`, per-user cron enumeration
- File permission analysis — `find` with `-perm /4000` (SUID), `-perm -0002` (world-writable)
- System integrity — `rpm -Va` checking for modified system binaries
- SELinux status — `getenforce`, `sestatus`
- Log analysis — `/var/log/secure`, `lastb`, `last`, `/var/log/messages`
- Bash history review — `/root/.bash_history`, `/home/*/.bash_history`
- Docker inspection — `docker ps`, `docker inspect`, `docker exec` for container-level checks
- Database analysis — direct `mysql` client queries for user permissions and access grants

All findings were recorded in real time and remediation commands were executed immediately where safe to do so. Configuration backups were created before any SSH configuration changes.